

Email Analysis:-

SOC Analyst

↳ Password "btlo"

- ① Delivered to:- who received the Email.
- ② Received: by :- it is the closest mail server to the Recipient. it appears "Top" in the mail.
- ③ Received: by:- The second received is close to the sender mail server. present in the "bottom".
- ④ X-headers:- It is optional which is added by tools and the servers.
- ⑤ ARC header:- Authenticated Received Chain header.
↳ These are used for Authentication purposes by having the trusted intermediate server.

↳ Digitally Signed Headers.

⑥ Return-Path:- where fail emails are return. It is used for troubleshoot.

⑦ Authentication-Results:-

↳ SPF / DKIM / and DMARC
(Sender Policy Framework)

SPF:- prevent attackers from sending email using a domain they don't own.

SPF = Pass — match the SPF record

SPF = Fail — not authorized (spoofing)

SPF = Soft Fail — fail but not rejected (gray area)

SPF = neutral — No strong decision on SPF validity

SPF = permerror — SPF misconfigured.

(DomainKeys Identified Mail)

↳ DKIM:- Prevent Email Tampering by digitally signing message.

↳ It send the public key (DKIM signature)

↳ Recipient mail server retrieves public

Key from DNS.

↳ If match DKIM passes.

DKIM = PASS → valid

DKIM = FAIL → invalid (may be altered)

DKIM = NONE → doesn't use DKIM

DKIM = neutral → No decision on validity.

DMARC (Domain-based Message Authentication, Reporting & Conformance)

↳ It handles SPF / DKIM failures.

↳ The recipient server check SPF and DKIM. If both fail then DMARC policy set by the sender's domain.

↳ The recipient send DMARC reports to Domain owner.

DMARC = PASS → Passed SPF + DKIM

DMARC = Fail → Failed SPF + DKIM (spoofing)

DMARC = None → No Policy is applied

DMARC = quarantine → Sent to SPAM.
DMARC = Reject → Blocked entirely.

⑧ To :- Recipient

⑨ Subject :-

⑩ From :- who send the email.

⑪ Reply To :- when you try to reply the email it used.

⑫ Content Type - It define the email body.

There are various type :-

↳ Text / Plain → Plain text → safe.

↳ Text / HTML → HTML format → Phishing Email.

↳ multipart / Mixed → Contain attachment → Phishing Email

↳ multipart / Alternative → Plain text + HTML version.
→ Phishing emails + legit mail.

↳ multipart/related → Embedded Images → fake invoices

↳ application/pdf → Pdf attachment → deliver payloads.

↳ application/zip → Zipfile → malware + Trojan

↳ application/msword → .doc file → Word Macros.

↳ application/vnd.ms-excel → .xls / .xlsx → Malicious Macros/script

↳ application/octet-stream → binary attachment → EXES, DLLS.

↳ image/jpeg → JPEG image → EXES as images.

↳ Content-Transfer Encoding: base 64 → base 64 encoding → script or payloads.

⑬ Boundary = It is used to set the boundary of rendering of content. It also set the start and stop rendering of content in certain format.

⑭ Message-ID:- unique identifier of the email.

⑮ Date:- when it is created (it may be spoofed).

Step 1:- Extract the file "b6lo" password

Step 2:- Check all the information

Step 3:- SPF is fail and Return-type is different which makes suspicious.
We need more investigation.

Step 4:- Open the file in the notepad. Check for the boundary value.

Step 5:- There is two boundary value :-
1. one for plain/Text
2. Two for Pdf.
Now, investigate one by one.

Step 6:- Copy first and use the "codechef" Tool for investigation

↳ In "codechef" copy all the base64 values and drag the "From Base64" from side bar.

↳ Now, check the decoded message.

Step 7:- Now check the second base64 file.

↳ Now open new tab and paste the 'Base64' data. It will display some cryptic values.

↳ Now drag the 'To Hex' for conversion.

↳ Now, it display Hex values. we can Identify the file signature. Investigate the first four digits. It is also called as:-

- | | |
|------------------|---------------------------------------|
| ① File Signature | } All are same present in first 4-hex |
| ② Magic Number | |
| ③ File Header | |

↳ Now copy the "4 digits" and check the number using:- "Gary Kessler File Signature"

↳ check the Number it display Zip file. It is malicious file. So, save the file in "Zip format" for further investigation.

Step 8:- After Extract we get 3 files:-

↳ For investigation we use "Hex editor" for that we install

→ sudo apt install ghex

→ ghex ↩

↳ Now copy first four number and check in "Gary Kessler file" signature (FF D8 FF E0)

↳ Now, check this operation for all the files.

↳ We have to create the ID in "Zoho.in" to open the ".xlsx" file.

Check ↳ We it opens first sheet have all the information the sheet 3 data hidden so change the color of font to view the information.

↳ Copy the flag and paste in codechef to decode in base64 format.

↳ Now, answer the question.

Answer 1:- "emkei.c7" is used to receive the mail.

Answer 2:- "negeja3921@pashtu.com"

Answer 3:- ".zip."

Answer 4:- "Pesturo Nageja"

Answer 5:- "The Martian Colony, Beside
Interplanetary Spaceport"

Answer 6:- "pashtur.com"